

Penetration Testing & Security Assessment Findings

Block Consulting | Infrastructure, Application & Compliance Security

Block Consulting conducts penetration tests and vulnerability assessments across enterprise infrastructure, web applications, and cloud environments. The findings presented here are representative, anonymised examples of vulnerabilities identified during authorised engagements.

Made with GAMMA



What We Assess

Network Penetration Testing

Internal and external assessments identifying exploitable paths across your network perimeter.

Web Application Assessments

Full-scope testing using OWASP methodology against modern and legacy web applications.

Cloud & Container Reviews

Configuration, access, and runtime security reviews across AWS, Azure, GCP, and container platforms.

Active Directory & Identity

Assessment of AD misconfigurations, privilege escalation paths, and identity infrastructure weaknesses.

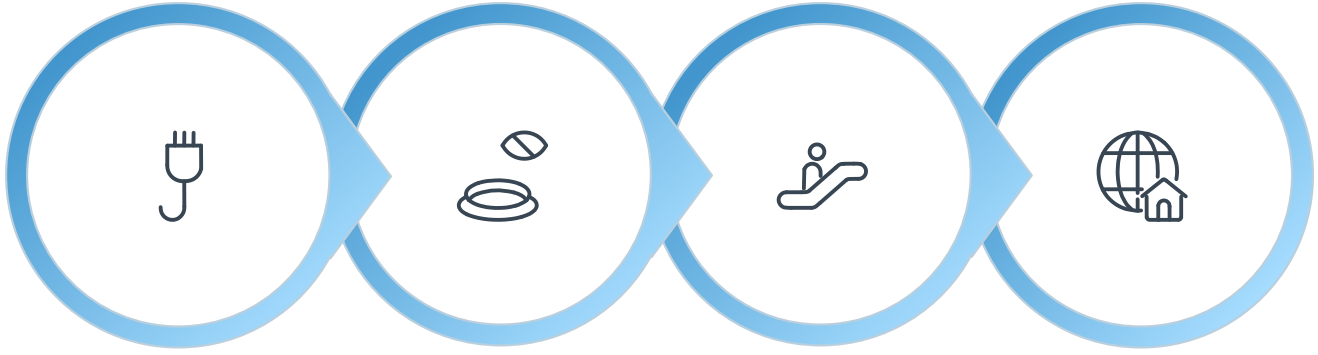
The following slides present a selection of typical findings from our engagements. Each represents a real vulnerability that could lead to unauthorised access, data breach, or system compromise.

Made with GAMMA

CRITICAL SEVERITY

Unpatched SMB Protocol — MS17-010

Legacy SMBv1 enabled unauthorised remote code execution



Initial Access | **SMBv1 Exploit** | **Privilege Escalation** | **DC Takeover**

Finding

Windows servers were identified still running SMBv1 — a legacy protocol with a well-documented critical vulnerability (EternalBlue). This requires no valid credentials to exploit.

Business Impact

Without valid credentials, an attacker with internal network access can traverse from a single foothold to full domain compromise in hours.

Full System Compromise

Ransomware Deployment

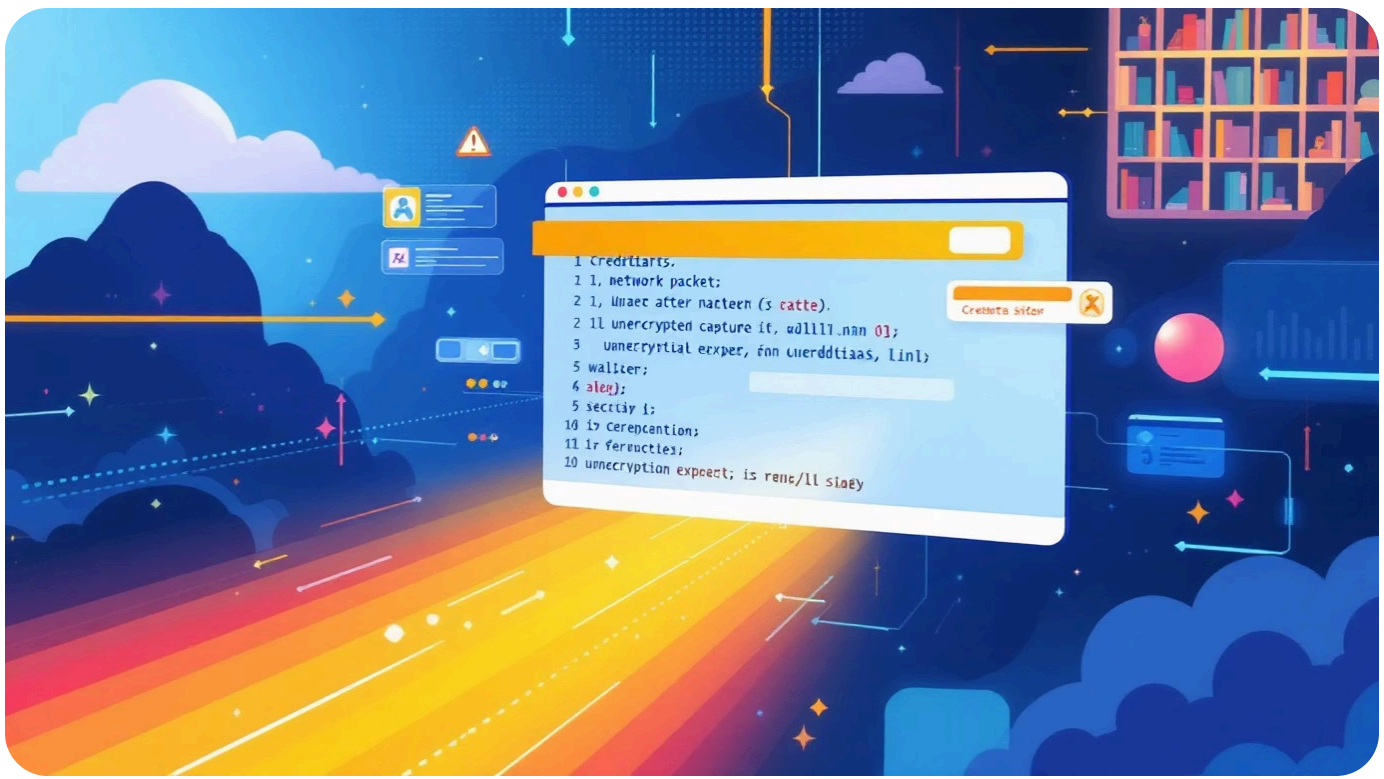
Domain Controller Takeover

Made with GAMMA

HIGH SEVERITY

Credentials Transmitted in Clear Text

Administrative credentials captured in transit across unencrypted authentication traffic



Finding

On administrative subnets, authentication traffic — including LDAP and NTLM exchanges — was transmitted without encryption. Any attacker with passive network access could capture credentials in plaintext using widely available tools.

Business Impact

- Credential theft without active exploitation
- Privilege escalation to sensitive systems
- Persistent attacker access and lateral movement

Made with GAMMA

MEDIUM SEVERITY

Service Accounts with Excessive Privileges

Finding

Application service accounts were configured with domain or local administrator rights — far beyond the minimum required. These accounts had never been rotated or reviewed against security policy. Compromising a single application grants an attacker highly privileged access across the environment.

Consequences

Privilege Escalation

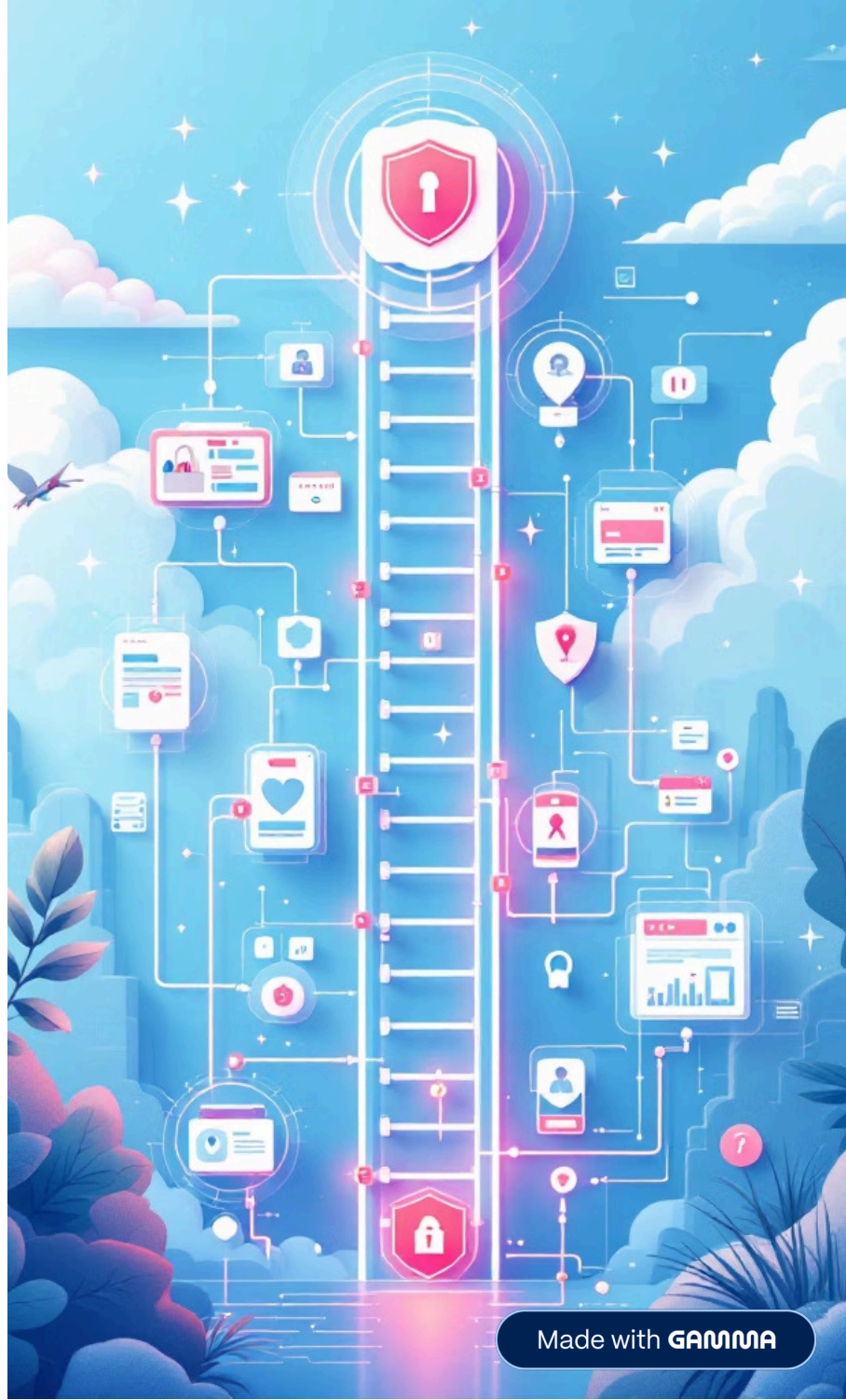
Attacker inherits admin rights via application exploit.

Lateral Movement

Broad access enables traversal across systems.

Persistence

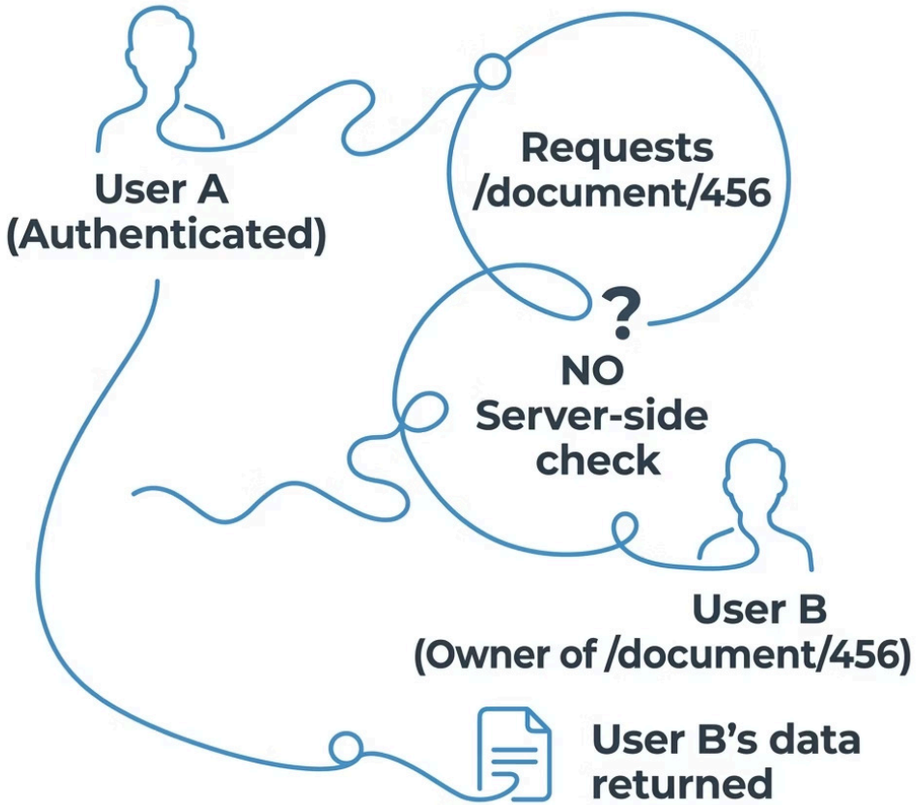
Abuse blends with legitimate account activity.



WEB APPLICATION — OWASP A01

Broken Access Control

Authenticated users could access other users' data by manipulating predictable URL parameters



Finding

A web application used sequential, predictable IDs in URLs — such as `/user/123` or `/document/456`. By incrementing or modifying the ID, an authenticated user could retrieve another user's records. No server-side authorisation check validated ownership.

Business Impact

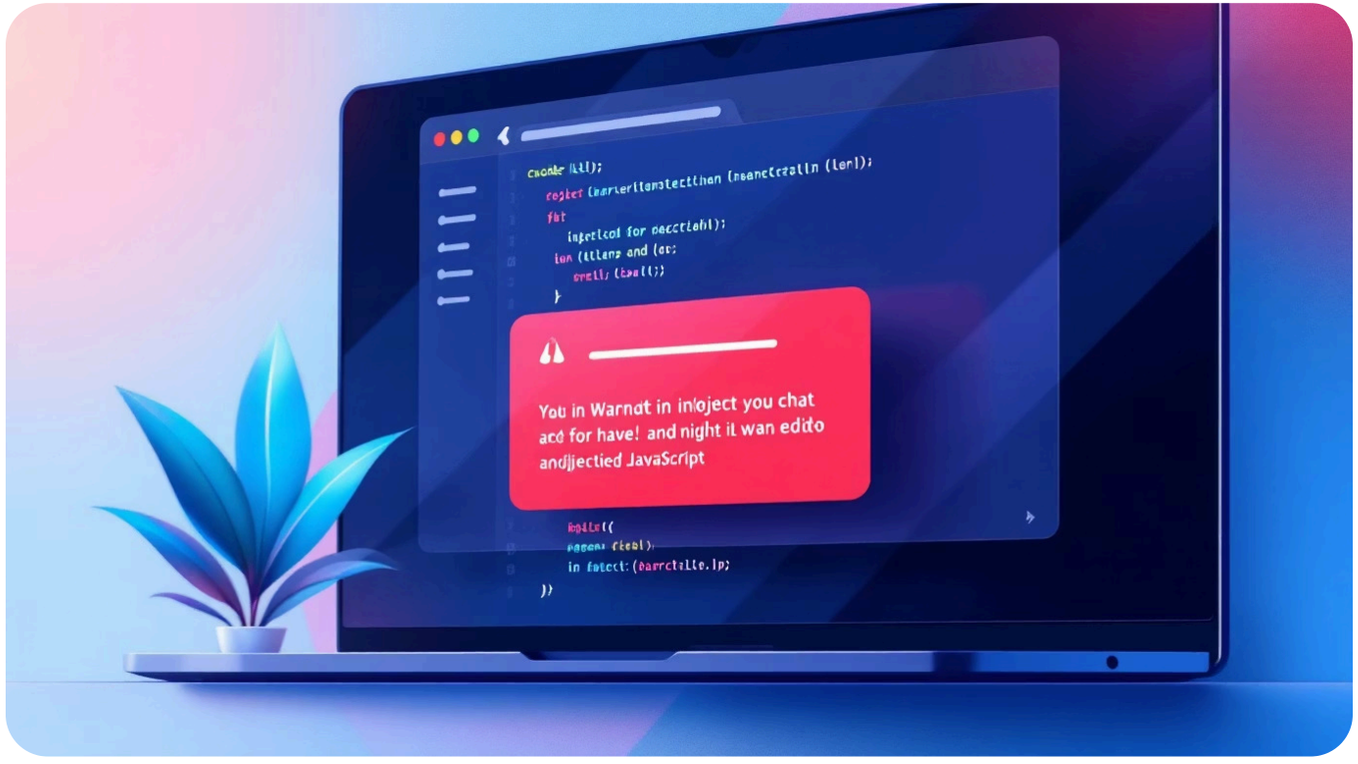
- Exposure of PII, financial data, or confidential documents
- GDPR and regulatory breach risk
- Reputational and legal consequences

Made with GAMMA

WEB APPLICATION

Cross-Site Scripting (XSS)

Unvalidated user input allowed malicious script injection into the browser of any visiting user



Finding

The application reflected or stored user-supplied input in rendered web pages without sanitisation. An attacker could inject malicious JavaScript that executes silently within another user's browser session, without any interaction beyond visiting the affected page.

Business Impact

Session Hijacking

Account Takeover

Credential & Data Theft

Malware Delivery

Made with GAMMA

SECURITY MISCONFIGURATION

Default Settings & Verbose Errors Exposed Sensitive Information

Default Credentials Unchanged

Systems deployed with vendor-default usernames and passwords — trivial for attackers to guess using public credential lists.

Unnecessary Services Enabled

Unused ports and services remained active, expanding the attack surface unnecessarily.

Debug Mode in Production

Error responses returned full stack traces, internal file paths, and framework versions — a roadmap for targeted exploitation.



Made with GAMMA

Real Risks, Real Impact



Full Network Compromise

Ransomware deployment and data exfiltration within hours of initial access.



Regulatory Exposure

Data breaches triggering GDPR, DORA, and sector-specific compliance obligations.



Unauthorised System Access

Sensitive applications, databases, and infrastructure accessible to unauthenticated or low-privilege users.



Reputational & Operational Damage

Service disruption, client notification obligations, and lasting damage to trust.

These findings were identified during authorised testing — **before exploitation by a real attacker**. Proactive penetration testing reduces risk and directly supports your compliance posture.

Made with GAMMA



Partner with Block Consulting

Specialist security assessments for enterprises — infrastructure, applications, and compliance.

Comprehensive Penetration Testing

Authorised, expert-led testing across your network, applications, cloud, and identity infrastructure.

Compliance-Aligned Assessments

Findings mapped to GDPR, DORA, ISO 27001, and relevant regulatory frameworks.

Actionable Remediation Guidance

Clear, prioritised recommendations your teams can act on — not just a list of vulnerabilities.

Ready to assess your security posture? Let Block Consulting conduct a thorough penetration test or vulnerability assessment of your infrastructure, applications, or cloud environment.

Made with GAMMA